



SIMATS
ENGINEERING



SIMATS
Saveetha Institute of Medical And Technical Sciences
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

Cloud-Based Identity and Access Management System with Federated Authentication

A CAPSTONE PROJECT REPORT

**Submitted in partial fulfilment of the requirements for the Course of
CSA1522 - CLOUD COMPUTING AND BIG DATA ANALYTICS**

towards the award of the degree of

BACHELOR OF ENGINEERING / TECHNOLOGY IN

INFORMATION TECHNOLOGY

Submitted by

DHILIBAN M (192421166)

Under the Supervision of

Dr P Rajaram

SIMATS ENGINEERING

**Saveetha Institute of Medical and Technical
Sciences Chennai-602105**

SEPTEMBER 2026

SIMATS ENGINEERING

**Saveetha Institute of Medical and Technical
Sciences Chennai-602105**

BONAFIDE CERTIFICATE

This is to certify that the Capstone Project entitled “Cloud-Based Identity and Access Management System with Federated Authentication” has been carried out by DHILIBAN M(192421166) under the supervision of Dr Rajaram P and is submitted in partial fulfilment of the requirements for the current semester of the B.Tech Information Technology program at Saveetha Institute of Medical and Technical Sciences, Chennai.

COURSE COORDINATOR

Dr. A. Gnana Soundari

Professor

CSE/Machine Learning

SIMATS Engineering,

SIMATS, Chennai – 602105.

COURSE FACULTY

Dr.P.RAJARAM

Professor

CSE/Data Vista

SIMATS Engineering,

SIMATS, Chennai – 602105.

SIMATS ENGINEERING

**Saveetha Institute of Medical and Technical
Sciences Chennai-602105**

DECLARATION

I, DHILIBAN M(192421166) of the B TECH IT, SIMATS Engineering, Saveetha Institute of Medical and Technical Sciences, Chennai, hereby declare that the Capstone Project Work entitled “Cloud-Based Identity and Access Management System with Federated Authentication” is the result of our own bonafide efforts. To the best of our knowledge, the work presented herein is original, accurate, and has been carried out in accordance with the principles of engineering ethics and academic integrity. All sources, references, data, and other materials used in the project have been appropriately acknowledged. We further declare that the data, results, analysis, and findings presented in this report have not been fabricated, falsified, or manipulated. Any external tools, software, datasets, computational resources, or AI-assisted tools used during the project have been appropriately disclosed. We confirm that all applicable ethical, academic, institutional, and professional requirements have been duly followed throughout the planning, execution, analysis, and documentation of the project.

Place: CHENNAI

Date: 02-09-2026

Signature of the Students with Names

SIMATS ENGINEERING
Saveetha Institute of Medical and Technical Sciences
Chennai–602105

INDIVIDUAL CONTRIBUTION STATEMENT

Student Name / Register No.	Specific Responsibilities	Design & Development Contribution	Testing & Analysis Contribution	Report Contribution	Approx. Contribution (%)
DHILIBAN M 192421166	Project architecture, end-to-end integration, identity/credential module, federation module, RBAC and audit logging, deployment verification.	Designed the layered IAM architecture; implemented credential management, OAuth2/SAML federation flow, and RBAC policy/audit engine; coordinated frontend-backend integration.	Performed end-to-end functional verification, token validation checks, RBAC boundary testing, audit-log completeness checks, and build/runtime debugging.	Prepared the individual contribution report, architecture explanation, testing tables, risk/security discussion, and final documentation.	60%
MADHAN R 192324256	Supporting implementation and module development within the team project.	Contributed to assigned software modules and feature implementation under the common project architecture.	Supported module-level testing and validation.	Contributed technical notes and project documentation.	20%
BUVANESH Y 192372367	Supporting implementation, validation and project activities within the team.	Contributed to assigned modules and integration activities.	Supported functional testing and demonstration preparation.	Contributed technical documentation and review.	20%
Total					100%

ABSTRACT

Modern organisations increasingly depend on multiple cloud-hosted applications, each of which traditionally requires its own set of credentials, session state and authorization rules. Managing identities separately across these applications fragments user experience, increases password-related risk, and makes centralized policy enforcement and auditing difficult. This project develops a Cloud-Based Identity and Access Management (IAM) System with Federated Authentication that provides a single, centrally governed identity layer across multiple cloud-hosted applications. The implemented prototype uses OAuth2/OpenID Connect and SAML2 as federation protocols, with Keycloak (and, where applicable, Firebase Authentication) as the identity provider, backed by a cloud-hosted relational database for identity, role and audit records. The system is organised into three connected modules: a User Identity & Credential Management module that handles registration, credential storage, password policy and multi-factor authentication; a Federated Single Sign-On module that lets a user authenticate once and be transparently trusted across every federated relying-party application through signed tokens/assertions; and an Access Policy Enforcement & Audit Logging module that applies role-based access control (RBAC) at the API boundary and produces a tamper-evident audit trail of every authentication and authorization decision. The system was validated through prototype scenarios covering successful and failed federated logins, token expiry and refresh, cross-application SSO propagation, role-based access denial, and audit-log completeness under normal and adversarial conditions. The results show that the federated architecture can convert a single authentication event into consistently enforced, auditable access across independently hosted cloud services, without requiring each relying application to re-implement authentication logic. The project remains a prototype scoped to a small set of demonstration applications and does not claim enterprise-scale production certification. The principal contribution of this report is the end-to-end design and integration of identity, federation and policy/audit layers into a coherent, demonstration-ready federated IAM platform.

Keywords: Identity and Access Management, Federated Authentication, OAuth2, SAML, Single Sign-On, Role-Based Access Control, Audit Logging, Cloud Security

TABLE OF CONTENTS

Sl. No.	Title	Page No.
i	CERTIFICATE FROM THE SUPERVISOR	ii
ii	DECLARATION BY THE CANDIDATE	iii
iii	INDIVIDUAL CONTRIBUTION STATEMENT	iv
iv	ABSTRACT	v
v	LIST OF FIGURES	vi
vi	LIST OF TABLES	vii
vii	LIST OF ABBREVIATIONS / SYMBOLS	viii
1	CHAPTER 1: INTRODUCTION AND ENGINEERING PROBLEM	
1.1	Background	1
1.2	Need for the Project	1
1.3	Problem Statement	2
1.4	Project Aim	2
1.5	Project Objectives	2
1.6	Scope	3
1.7	Expected Engineering Outcome	3
2	CHAPTER 2: LITERATURE REVIEW AND EXISTING SOLUTIONS	4
2.1	Review Method	4
2.2	Review of Existing Work	4
2.3	Comparative Analysis	5
2.4	Research / Engineering Gap	6
2.5	Proposed Contribution	6
3	CHAPTER 3: ENGINEERING DESIGN & TRADE-OFFS, SUSTAINABILITY, ETHICS, SAFETY, RISK & SECURITY	
3.1	Requirements	7
3.2	Constraints & Applicable Standards	8
3.3	Design Specifications	8
3.4	Alternative Solutions & Evaluation	9
3.5	Selected Design & Detailed Design	9
3.6	Trade-off Analysis	10
3.7	Sustainability, Ethics, Safety & Security	11
3.8	Risk Register	11
4	CHAPTER 4: IMPLEMENTATION, TESTING & RESULTS, PROJECT MANAGEMENT	

Sl. No.	Title	Page No.
4.1	Development Approach & Resources	13
4.2	Software Implementation & Modern Tools Used	13
4.3	Test Plan & Verification	14
4.4	Results	15
4.5	Data Analysis & Engineering Judgment	16
4.6	Comparison with Existing Solutions & Achievement of Objectives	16
4.7	Strengths & Limitations	17
4.8	Project Planning, Roles & Budget	17
5	CHAPTER 5: CONCLUSION, FUTURE WORK AND REFLECTION	
5.1	Conclusion	19
5.2	Future Work	19
5.3	Professional Learning & Individual Reflection	20
	REFERENCES	22
	APPENDICES	23

LIST OF FIGURES

Figure No.	Figure Name	Page No.
A.1	System architecture of the federated IAM platform	23
A.2	Federated SSO authentication and authorization sequence flow	24

LIST OF TABLES

Table No.	Table Name	Page No.
2.1	Comparative Analysis	5
3.1	Stakeholder Requirements	7
3.2	Functional and Non-Functional Requirements	8
3.3	Constraints & Applicable Standards	8
3.4	Design Specifications	8
3.5	Alternative Solutions & Evaluation	9
3.6	Trade-off Analysis	10
3.7	Sustainability, Ethics, Safety & Security	11
3.8	Risk Register	11
4.1	Implementation Tools and Resources	13
4.2	Software Implementation & Modern Tools Used	14
4.3	Test Plan and Verification	15
4.4	Prototype Test Results	16
4.5	Comparison with Existing Solutions & Achievement of Objectives	16
4.6	Project Planning and Individual Roles	17
4.7	Budget Summary	18

LIST OF ABBREVIATIONS / SYMBOLS

Symbol	Description	Unit
API	Application Programming Interface	—
CORS	Cross-Origin Resource Sharing	—
IAM	Identity and Access Management	—
IdP	Identity Provider	—
JWT	JSON Web Token	—
MFA	Multi-Factor Authentication	—
OAuth2	Open Authorization 2.0	—
OIDC	OpenID Connect	—
OWASP	Open Worldwide Application Security Project	—
RBAC	Role-Based Access Control	—
REST	Representational State Transfer	—
SAML	Security Assertion Markup Language	—
SLA	Service Level Agreement	—
SP	Service Provider	—
SSO	Single Sign-On	—
TLS	Transport Layer Security	—

CHAPTER 1

INTRODUCTION AND ENGINEERING PROBLEM

1.1 Background

Cloud-hosted software is rarely delivered as a single monolithic application. Organisations typically operate a portfolio of independently deployed web applications, APIs, administrative dashboards and partner-facing services, each of which needs to know who a user is and what that user is allowed to do. Historically, each application solved this problem on its own: separate user tables, separate password hashes, separate session cookies and separate authorization rules. This per-application approach multiplies the attack surface, increases the burden of password management on users, and makes it difficult for an organisation to answer a simple governance question — who can access what, and when did they access it.

Federated identity research reframes authentication as a trust relationship rather than a local database lookup. An Identity Provider (IdP) authenticates the user once and issues a signed, verifiable statement of identity that other applications, acting as Service Providers (SPs) or relying parties, can trust without re-collecting credentials. OAuth 2.0 and OpenID Connect (OIDC) formalise authorization delegation and identity assertion for modern web and API-driven architectures, while the Security Assertion Markup Language (SAML) established an earlier, XML-based approach to browser-based federation widely used in enterprise single sign-on. Both protocol families remain in active use, and a practical cloud IAM platform typically needs to support both.

The implemented project combines a federation gateway with a policy-and-audit layer. Keycloak is used as the identity broker and token issuer, backed by a cloud-hosted relational database that stores identity, role and audit records. The resulting architecture follows a continuous authenticate → federate → authorize → audit loop rather than treating login, cross-application trust and access governance as unrelated concerns.

1.2 Need for the Project

- User identity is frequently duplicated across applications, creating inconsistent credentials, orphaned accounts and inconsistent password policies.
- Manually re-authenticating for every cloud application increases login friction and encourages weak or reused passwords.
- Access decisions made independently by each application make it difficult to apply a single, consistent authorization policy across the organisation.
- Security incidents are hard to investigate when authentication and access events are not centrally logged in a tamper-evident form.
- Onboarding and offboarding a user across many applications is slow and error-prone without a central identity and role authority.

The engineering need is therefore an integrated identity layer that can authenticate a user once, propagate that trust safely across federated applications, enforce role-based access consistently at each protected boundary, and produce a complete, auditable record of every authentication and authorization decision.

1.3 Problem Statement

Design and implement a prototype cloud-based Identity and Access Management platform that authenticates users once, federates that authentication across multiple independently hosted cloud applications using open standards (OAuth2/OIDC and SAML2), enforces role-based access control at each protected resource, and maintains a complete audit trail of authentication and authorization events, under realistic constraints of token security, session lifecycle management, multi-application trust configuration and prototype-scale infrastructure.

The problem is complex because the system must simultaneously satisfy low-latency authentication, correct and replay-resistant token/assertion validation, consistent policy enforcement across heterogeneous relying applications, safe secret and key management, and non-repudiable audit logging, without degrading the user experience that SSO is meant to improve.

1.4 Project Aim

To design and develop a Cloud-Based Identity and Access Management System with Federated Authentication that integrates centralized credential management, standards-based federated single sign-on, and policy-driven access enforcement with audit logging, so that users authenticate once and securely access multiple federated cloud services under centrally governed, auditable access policy.

1.5 Project Objectives

1. Design an end-to-end architecture connecting credential management, identity federation, policy enforcement and audit logging.
2. Implement secure user registration, credential storage and multi-factor authentication for the identity provider.
3. Configure standards-based federation (OAuth2/OIDC and SAML2) so that a single login is trusted by multiple relying-party applications.
4. Design and enforce a role-based access control (RBAC) model at protected API and application boundaries.
5. Implement structured, tamper-evident audit logging of authentication and authorization events.
6. Validate token/assertion issuance, expiry, refresh and revocation behaviour.
7. Validate the system through functional, security and end-to-end federation tests.
8. Document the engineering trade-offs, risks, limitations and individual contribution.

1.6 Scope

Included scope: user registration and credential management; password policy and multi-factor authentication; OAuth2/OIDC authorization-code flow; SAML2 browser SSO profile; centralized

session and token management; role-based access control at the API gateway and application layer; structured audit logging; an administrative console for identity, role and policy management; and a small set of demonstration relying-party applications.

Excluded scope: certified enterprise-wide production deployment across an unbounded number of applications, integration with an organisation's existing legacy directory (e.g. Active Directory) beyond a documented extension point, hardware security module (HSM)-backed key custody, and a fully independent third-party security certification/pen-test. The project records treat directory-synchronisation, HSM-backed key management and formal third-party penetration testing as future extensions.

Assumptions and boundaries include a small number of demonstration relying-party applications, controlled test scenarios, available network connectivity during normal operation, configured role and policy definitions, and human review for high-impact administrative actions such as role escalation.

1.7 Expected Engineering Outcome

The intended outcome is a working prototype that demonstrates a complete identity-to-access chain: user credential submission → identity provider authentication → federated token/assertion issuance → relying-party trust validation → role-based access decision → audit record creation. The outcome is therefore both a security-relevant software platform and a demonstration of standards-based identity federation across multiple cloud-hosted applications.

CHAPTER 2

LITERATURE REVIEW AND EXISTING SOLUTIONS

2.1 Review Method

The literature review was conducted using peer-reviewed journal and conference records, standards documents (NIST, IETF, OASIS), publisher pages and ResearchGate/Google Scholar-indexed records. Search themes included OAuth2 and OpenID Connect security, SAML single sign-on, role-based access control models, zero-trust architecture, and identity and access management in cloud computing. The review emphasized papers and standards with identifiable publication details and DOI information.

The reviewed sources were compared against the design of the implemented system rather than copied as text. The review was used to identify the engineering gap and to justify the combination of federated authentication, standards-based token issuance, RBAC enforcement and audit logging in a single integrated platform.

2.2 Review of Existing Work

Fett, Küsters and Schmitz [1] carry out a comprehensive formal security analysis of OAuth 2.0, covering all four grant types and establishing authorization, authentication and session-integrity properties under an expressive web attacker model. Their analysis identifies conditions under which OAuth 2.0 can be considered secure and highlights implementation pitfalls that motivated later best-practice guidance such as PKCE. This project follows the authorization-code flow with PKCE precisely to avoid the classes of attack this analysis identifies.

Gross [2] presents an early but influential security analysis of the SAML Single Sign-On Browser/Artifact profile, identifying protocol-level flaws that can lead to vulnerable implementations if left unmitigated. This work motivates strict validation of SAML assertion signatures, audience restrictions and replay protection in the federation module of this project.

Sandhu, Coyne, Feinstein and Youman [3] introduce the foundational role-based access control (RBAC) model, separating users, roles and permissions so that authorization can be managed at the role level rather than per individual user. Ferraiolo, Sandhu, Gavrila, Kuhn and Chandramouli [4] extend this into the NIST-proposed RBAC standard with flat, hierarchical, constrained and symmetric levels. These works form the direct theoretical basis for the access-policy module implemented in this project.

Rose, Borchert, Mitchell and Connelly [5], in NIST SP 800-207, describe a zero-trust architecture in which authentication and authorization are treated as discrete, continuously evaluated functions rather than one-time perimeter checks. This principle informs the decision to re-validate tokens and re-evaluate role policy at every protected resource boundary in this project, rather than trusting a session indefinitely after initial login.

Indu, Rubesh Anand and Bhaskar [6] survey identity and access management mechanisms specific to cloud environments, covering authentication, SSO, federation and access-control delegation, and highlighting multi-tenancy and third-party-managed infrastructure as sources of additional risk. Their survey supports the architectural choice of a dedicated federation gateway rather than embedding authentication logic separately inside each cloud application.

Collectively, these works support treating federated identity as a security-critical, standards-governed subsystem rather than an implementation detail of any single application, and they motivate the specific combination of OAuth2/OIDC, SAML2, RBAC and continuous audit logging adopted in this project.

2.3 Comparative Analysis

Existing Approach	Advantages	Limitations	Relevance to This Project
Per-application local authentication	Simple to implement for a single app; no external dependency	Duplicated credentials, inconsistent policy, no cross-app SSO	Motivates a shared identity provider and federation gateway
OAuth2/OIDC-only platforms	Modern token-based flows; good for APIs and SPAs	Not natively suited to legacy SAML-only relying parties	Provides the primary federation protocol; SAML2 retained for legacy-style SSO
SAML-only enterprise SSO	Mature browser-based SSO; widely supported by enterprise apps	XML complexity; weaker fit for modern mobile/API clients	Retained for enterprise-style relying parties alongside OAuth2/OIDC
RBAC research [3], [4]	Simplifies authorization management at scale	Requires disciplined role design to avoid role explosion	Directly adopted for the access-policy module
Zero-trust guidance [5]	Removes implicit trust based on network location	Requires re-validation overhead at every boundary	Adopted for continuous token/role re-validation
Cloud IAM surveys [6]	Broad view of cloud-specific authentication/access challenges	General guidance, not a deployable architecture	Used to justify the layered federation + policy + audit design

2.4 Research / Engineering Gap

The reviewed literature provides strong solutions for individual dimensions of identity and access management — protocol security, access-control theory, and continuous-verification principles — but a demonstrable, prototype-scale system still needs a practical integration path that connects credential management, standards-based federation, RBAC enforcement and audit logging into one coherent, testable platform. The gap addressed by this project is that integration: showing that a single authenticated session can be safely and verifiably trusted across independently hosted applications, with every authorization decision both policy-governed and logged.

A second gap is traceability. A federation layer may issue technically valid tokens while still failing operationally if a relying application does not correctly validate signatures, audiences and expiry, or if an access decision is never recorded. This project therefore treats the transition between the federation layer, the policy layer and the audit layer as an explicit engineering requirement rather than an implementation afterthought.

2.5 Proposed Contribution

The proposed contribution is an integrated prototype architecture in which a single sign-on event, once issued by the identity provider, propagates through signed tokens/assertions to multiple relying applications, is checked against a role-based policy at each protected resource, and is recorded in a structured, append-only audit log. The project also introduces a configurable RBAC policy model, centralized MFA enforcement at the identity provider, and token lifecycle management (issuance, refresh, expiry and revocation) as connected rather than isolated features.

CHAPTER 3

ENGINEERING DESIGN & TRADE-OFFS, SUSTAINABILITY, ETHICS, SAFETY, RISK & SECURITY

3.1 Requirements

Stakeholder	Requirement
Administrator / IAM owner	Central console for managing users, roles, policies, federated applications and audit visibility.
Application developer (relying party)	Simple, standards-based way to integrate authentication without re-implementing credential storage.
End user	Single set of credentials, single login, and consistent access experience across federated applications.
Security / compliance reviewer	Enforced role-based access, MFA where required, and a complete, tamper-evident audit trail.
Project evaluator	Reproducible prototype workflow with visible evidence of federation, RBAC and audit logging.

Requirement	Type	Measurable Target
User registration & credential storage	Functional	Credentials accepted, validated and stored using salted password hashing; duplicate accounts rejected.
Federated SSO issuance	Functional	A single successful login issues a valid OAuth2/OIDC token or SAML2 assertion accepted by every configured relying application.
Token/assertion validation	Functional	Relying applications reject expired, tampered or wrong-audience tokens/assertions.
RBAC enforcement	Functional	Protected endpoints reject requests from roles without the required permission.
Audit logging	Functional	Every authentication and authorization decision produces a persisted, timestamped audit record.
Authentication success rate	Non-Functional	Valid-credential logins succeed consistently under normal test conditions.
SSO login latency	Non-Functional	End-to-end federated login completes within an acceptable interactive response time in prototype testing.
Security	Non-Functional/Security	Secrets, keys and tokens are never exposed in logs or client-readable storage; TLS enforced in transit.
Maintainability	Non-Functional	Modules separated by credential management, federation, and policy/audit responsibilities.

3.2 Constraints & Applicable Standards

Standard / Code	Requirement	How Applied in This Project
RFC 6749 / RFC 6819 (OAuth 2.0 & Threat Model)	Authorization framework and known threat mitigations	Authorization-code grant with PKCE used; implicit grant avoided per current best practice.

Standard / Code	Requirement	How Applied in This Project
OpenID Connect Core 1.0	Identity layer on top of OAuth2	ID tokens used for authentication in addition to OAuth2 access tokens.
OASIS SAML 2.0	XML-based federation for browser SSO	SAML2 Web Browser SSO profile supported for enterprise-style relying parties.
NIST SP 800-207 (Zero Trust)	Continuous verification, no implicit trust	Tokens and roles are re-validated at each protected resource rather than trusted for a whole session.
ISO/IEC 27001 principles	Information security management	Least privilege, role-based access, and controlled audit records applied throughout.
OWASP ASVS / Top 10	Application security	Input validation, secure secret storage, protected endpoints, and avoidance of privilege escalation.

3.3 Design Specifications

Parameter	Target / Requirement	Unit	Priority
Authentication protocols	OAuth2/OIDC (authorization code + PKCE) and SAML2 Web Browser SSO	—	High
Identity provider	Keycloak realm (with Firebase Auth as an alternate/social IdP option)	—	High
Database	Cloud-hosted relational database for identity, role and audit records	—	High
Frontend	Role-aware web application and admin console	—	High
Session/token model	Short-lived access tokens + refresh tokens; configurable expiry	state	High
RBAC model	Users → Roles → Permissions, evaluated at each protected endpoint	state	High
Audit record	Actor, action, resource, decision, timestamp, correlation ID	record	High
MFA	Time-based one-time password (TOTP) as a configurable second factor	—	Medium

3.4 Alternative Solutions & Evaluation

Alternative 1: A per-application local authentication scheme would be simple to implement for a single app but would not provide cross-application SSO or centralized policy/audit.

Alternative 2: A fully custom-built federation protocol (rather than adopting OAuth2/OIDC and SAML2) could theoretically be tailored to specific needs, but would forgo the peer-reviewed security analysis, tooling and relying-party interoperability that established standards provide.

Alternative 3: The selected architecture adopts a standards-based identity broker (Keycloak) for federation, a cloud-hosted database for identity/role/audit data, and a policy-enforcement layer applied

uniformly across relying applications. It provides a practical balance between standards compliance, extensibility and engineering complexity for a capstone-scale prototype.

Criterion	Weight	Local Per-App Auth	Custom Federation Protocol	Selected Standards-Based IAM
Security	30%	Low–Medium	Unproven	High (standards + peer-reviewed analysis)
Interoperability	25%	Low	Low (non-standard)	High (OAuth2/OIDC/SAML2)
Cost	15%	Low	High (build effort)	Low–Medium (open-source stack)
Maintainability	15%	Low	Low	High (modular, documented protocols)
Auditability	15%	Low	Medium	High (centralized audit layer)
Overall	100%	Weak fit	Weak fit	Best fit for capstone constraints

3.5 Selected Design & Detailed Design

The selected design uses a layered architecture. The credential layer (Module 1) handles registration, password policy, credential storage and MFA. The federation layer (Module 2) authenticates the user once at the identity provider and issues signed OAuth2/OIDC tokens or SAML2 assertions that relying applications trust without re-collecting credentials. The policy and audit layer (Module 3) evaluates RBAC rules at every protected resource and writes a structured audit record for each authentication and authorization decision.

The identity-to-access boundary is the most important integration point. When a user authenticates at the identity provider, the federation gateway issues a token/assertion bound to that user's roles. Each relying application validates the token/assertion signature, audience and expiry before honouring it, then forwards the request to the policy layer, which checks the caller's role against the resource's required permission and logs the decision. This avoids re-implementing authentication logic inside every application and makes the chain from login to access decision traceable end-to-end.

The architecture is modular so that the identity provider, token format, or policy engine can be replaced or expanded without rewriting the credential and relying-application layers. Additional relying applications can be onboarded as new federation clients without modifying the core identity or policy services.

3.6 Trade-off Analysis

Design Decision	Alternative Considered	Benefit	Disadvantage	Final Decision & Justification
OAuth2/OIDC with PKCE	Implicit grant	Simpler client-side flow historically	Tokens exposed in URL fragment;	Authorization code + PKCE selected per current best practice

Design Decision	Alternative Considered	Benefit	Disadvantage	Final Decision & Justification
			deprecated for security reasons	
Keycloak as identity broker	Fully custom-built IdP	Full control over every detail	High implementation and security-review effort	Keycloak selected for standards compliance and reduced attack surface
Dual protocol support (OAuth2/OIDC + SAML2)	OAuth2/OIDC only	Simpler single-protocol stack	Excludes SAML-only legacy/enterprise relying parties	Dual support selected to demonstrate broader federation coverage
Centralized RBAC policy service	Per-application authorization logic	Simple for a single app	Inconsistent policy across apps; duplicated logic	Centralized policy selected to guarantee consistent enforcement
Structured append-style audit log	Ad hoc application logging	Minimal extra effort	Hard to reconstruct cross-application access history	Structured audit log selected for traceability and compliance review

3.7 Sustainability, Ethics, Safety & Security

Domain	Consideration	Evidence Evaluated	Impact on Final Decision
Sustainability	Use reusable, open-source components and modular services.	Keycloak, PostgreSQL/cloud DB, open protocol standards, modular service boundaries.	Reduced dependency on proprietary identity infrastructure; supports extension.
Ethics	Avoid granting excessive or silent privilege escalation.	RBAC least-privilege defaults; administrative role changes require review.	Access changes remain visible and attributable, not silently automated.
Safety	Incorrect access decisions can expose sensitive data or block legitimate work.	RBAC boundary testing, token-expiry testing, fail-closed defaults on validation failure.	Protected resources default to deny when validation is inconclusive.
Security	Credentials, tokens and audit data are highly sensitive.	Salted password hashing, short-lived tokens, TLS in transit, least-privilege DB access, structured audit trail.	Public/relying-party views expose only what each role is entitled to see.

3.8 Risk Register

Risk	Likelihood	Severity	Risk Level	Mitigation	Residual Risk
Token theft / replay	Medium	High	High	Short token lifetime, audience/signature validation, HTTPS-only transport	Medium

Risk	Likelihood	Severity	Risk Level	Mitigation	Residual Risk
Misconfigured relying-party trust	Medium	High	High	Documented onboarding checklist; automated trust-config validation tests	Medium
Privilege escalation via role misassignment	Low–Medium	High	Medium–High	RBAC review workflow, least-privilege defaults, audit visibility on role changes	Low–Medium
Identity provider outage	Low–Medium	High	Medium	Health checks, session-refresh handling, documented fallback procedure	Medium
Incomplete audit logging under failure	Medium	Medium	Medium	Fail-closed logging path; log-write verification in tests	Low–Medium
Weak/reused user passwords	High	Medium	High	Password policy enforcement and optional/required MFA	Medium
Key/secret leakage	Low	High	High	Secrets kept out of source control; environment-scoped configuration	Low–Medium

CHAPTER 4

IMPLEMENTATION, TESTING & RESULTS, PROJECT MANAGEMENT

4.1 Development Approach & Resources

Development followed an incremental integration approach. The system was first decomposed into credential-management, federation and policy/audit responsibilities. Interfaces were then connected through defined API contracts, OAuth2/OIDC and SAML2 configuration, and a shared identity/role data model. Testing was performed from individual module behaviour toward the complete authenticate-to-audit workflow. This approach was particularly important because a successful login screen alone does not prove that token issuance, signature validation, role enforcement and audit-log persistence work together correctly across independently hosted relying applications.

Resource / Component	Purpose
Keycloak (Identity Provider)	Realm, client and federation configuration; OAuth2/OIDC and SAML2 token/assertion issuance
Firebase Authentication (optional IdP)	Social/alternate login option federated into the same trust chain
Backend API (REST)	Business logic, protected endpoints, RBAC policy evaluation
Cloud relational database	Persistent identity, role, session and audit records
React / web frontend	Role-aware user interface and administrative console
Relying-party demo applications	Two to three sample applications federated via the identity provider
Reverse proxy / API gateway	TLS termination, routing, and centralized token validation checkpoint
Audit logging service	Structured, timestamped record of authentication and authorization events

4.2 Software Implementation & Modern Tools Used

The prototype was assembled around a Keycloak realm configured with an OAuth2/OIDC client and a SAML2 service-provider integration, fronted by a backend API that performs token/assertion validation and RBAC policy evaluation before allowing access to protected resources. The three project modules — User Identity & Credential Management, Federated Single Sign-On, and Access Policy Enforcement & Audit Logging — were implemented as clearly separated services connected through documented API contracts, so that the relationship between a login event and its downstream access decisions is traceable during demonstration.

Tool / Software	Purpose	Stage Used
Keycloak	Identity provider, federation broker, token/assertion issuance	Identity & federation implementation
Firebase Authentication	Alternate/social identity provider federated into Keycloak	Identity & federation implementation
OAuth2 / OpenID Connect libraries	Authorization-code + PKCE flow, ID/access token handling	Backend implementation

Tool / Software	Purpose	Stage Used
SAML2 toolkit	SP-side assertion parsing and signature validation	Backend implementation
Cloud relational database (e.g. PostgreSQL)	Identity, role, session and audit persistence	Database implementation
React + TypeScript	Role-aware web interface and admin console	Frontend implementation
API gateway / reverse proxy	TLS termination and centralized token validation checkpoint	Deployment stage
Git/GitHub	Version control and integration	Development management
Cloud deployment tooling	Hosting and deployment verification	Deployment stage

4.3 Test Plan & Verification

The test plan was defined around the system's observable transitions rather than only code compilation. Each test checks whether an input creates the expected state change while preserving security and data integrity.

Requirement	Test Method	Acceptance Criterion
Registration & credential storage	Register a new user with valid/invalid inputs	Valid users stored with hashed credentials; invalid/duplicate inputs rejected
OAuth2/OIDC login	Complete authorization-code + PKCE flow	Valid ID/access token issued and accepted by the relying app
SAML2 login	Complete SP-initiated SSO flow	Valid signed assertion issued and accepted by the relying app
Cross-application SSO	Log in once, navigate to a second federated app	Second app recognizes the session without a fresh credential prompt
Token expiry	Wait for/force token expiry	Expired token rejected; refresh flow issues a new valid token
Tampered token/assertion	Modify a token/assertion payload or signature	Relying application rejects the tampered token/assertion
RBAC enforcement	Call a protected endpoint with an under-privileged role	Access denied / HTTP 403 at the protected boundary
MFA challenge	Trigger login for an MFA-enabled account	Second factor required before token/assertion issuance

Requirement	Test Method	Acceptance Criterion
Audit log completeness	Perform a sequence of login/access actions	Each action produces a corresponding, correctly timestamped audit record
Session revocation	Revoke a session/token from the admin console	Subsequent requests using the revoked token are rejected

4.4 Results

Test Case	Expected Result	Observed / Verified Result	Status
Registration & credential storage	User created with hashed credentials	Prototype record confirms hashed storage and duplicate rejection	PASS
OAuth2/OIDC login	Valid token issued	Authorization-code + PKCE flow completes and issues a valid token	PASS
SAML2 login	Valid assertion issued	SP-initiated flow completes and issues a valid signed assertion	PASS
Cross-application SSO	Second app trusts existing session	Second federated app grants access without re-prompting for credentials	PASS
Token expiry & refresh	Expired token rejected; refresh succeeds	Expired-token rejection and refresh-token renewal both confirmed	PASS
Tampered token/assertion	Rejected at relying application	Signature/audience validation rejects the modified token/assertion	PASS
RBAC enforcement	Under-privileged access denied	Protected endpoint returns access-denied for insufficient role	PASS
Audit log completeness	Every action logged	Login, access-grant and access-denial events all produce audit records	PASS

The project records do not provide a statistically validated enterprise-scale performance benchmark, so no unsupported throughput or latency figure is reported here. The meaningful result for this capstone is the successful integration of the end-to-end federated identity workflow and the repeatable functional verification of its major transitions.

4.5 Data Analysis & Engineering Judgment

The most important engineering observation was that failures at module boundaries are more consequential than failures inside an isolated component. For example, a valid login is useful only if the resulting token/assertion is correctly validated by the relying application, matched against the current role definition, and reflected in an access decision. Likewise, an access decision has limited governance value if it is not recorded in the audit log.

The testing therefore emphasized state propagation across the identity-to-access chain. A successful test was treated as evidence that the next layer received and correctly interpreted the previous layer's output. This approach exposed integration issues — such as clock-skew-related token rejection and inconsistent audience configuration — earlier than a screen-by-screen demonstration would have done. It also led to stronger emphasis on fail-closed behaviour, token lifecycle handling, and explicit audit-write verification.

4.6 Comparison with Existing Solutions & Achievement of Objectives

Objective	Evidence	Achievement
Design integrated architecture	Layered architecture connecting credential, federation and policy/audit modules	Fully Achieved
Secure credential management	Registration, hashed storage, password policy, MFA	Fully Achieved
Federated SSO	OAuth2/OIDC and SAML2 flows validated across demo relying apps	Fully Achieved at prototype level
RBAC enforcement	Role-based access denial verified at protected endpoints	Fully Achieved at prototype level
Audit logging	Complete audit records for login/access events	Fully Achieved at prototype level
Token lifecycle management	Expiry, refresh and revocation behaviour verified	Fully Achieved at prototype level
Enterprise-scale certified deployment	Formal security certification / large-scale load testing	Not claimed / Future work

4.7 Strengths & Limitations

Strengths:

- Standards-based federation (OAuth2/OIDC and SAML2) rather than a proprietary authentication scheme.
- Modular architecture separating credential management, federation and policy/audit responsibilities.
- Consistent RBAC enforcement applied uniformly across relying applications rather than per-app logic.
- Structured, queryable audit trail supporting traceability of authentication and access decisions.
- Fail-closed defaults on token/assertion validation failure protect against ambiguous trust states.

Limitations:

- Prototype federation is demonstrated with a small number of relying applications, not an enterprise-wide portfolio.
- Key custody relies on environment-scoped secrets rather than a hardware security module.
- No independent third-party penetration test has been performed on the prototype.

- Legacy directory integration (e.g. Active Directory/LDAP sync) is documented as an extension point but not implemented.
- High-impact administrative actions such as role escalation still require human review.

4.8 Project Planning, Roles & Budget

Phase	Major Activity	My Contribution
1	Problem analysis and architecture	Defined system boundary, module interfaces and the authenticate-to-audit workflow.
2	Identity & credential module	Implemented registration, credential storage, password policy and MFA.
3	Federation module	Configured Keycloak realm, OAuth2/OIDC and SAML2 clients, and relying-party trust.
4	Policy & audit module	Implemented RBAC policy evaluation and structured audit logging.
5	Security and quality review	Reviewed token handling, secret management, fail-closed behaviour.
6	Testing and deployment	Performed end-to-end validation, debugging and deployment verification.

Budget Item	Estimated Cost (₹)	Actual / Project Basis
Cloud hosting / compute (prototype tier)	[Fill in]	Prototype purchase/subscription basis
Managed database (prototype tier)	[Fill in]	Prototype purchase/subscription basis
Domain / TLS certificate	[Fill in]	Prototype purchase basis
Identity provider hosting (if not self-hosted)	[Fill in]	Prototype purchase/subscription basis
Miscellaneous / contingency	[Fill in]	Prototype planning basis
Approximate total	[Fill in]	As recorded in project budget planning

CHAPTER 5

CONCLUSION, FUTURE WORK AND REFLECTION

5.1 Conclusion

This project demonstrates how a cloud-based Identity and Access Management prototype can move beyond isolated, per-application login screens by connecting credential management, standards-based federated authentication and policy-driven access enforcement into a single governed workflow. The implemented system combines a Keycloak-based identity provider, OAuth2/OIDC and SAML2 federation, role-based access control, and structured audit logging across a small set of demonstration relying applications.

The core engineering contribution documented in this report is the integration of these modules into a coherent end-to-end system. The architecture was designed so that a single authentication event can propagate, through signed tokens and assertions, into consistent access decisions and audit records across independently hosted applications. This system-level view was essential for testing, because it exposed interface and trust-configuration issues that would not be visible from a single application's login screen alone.

The prototype achieved its principal capstone objective: demonstrating a practical, standards-based federated identity and access management workflow at prototype scale. It does not claim enterprise-wide production certification or independent penetration-test validation. Instead, it provides a technically defensible foundation that can be extended with directory integration, hardware-backed key custody and formal security testing.

5.2 Future Work

- Integrate with an organisational directory (e.g. LDAP/Active Directory) for enterprise-scale identity synchronisation.
- Adopt hardware security module (HSM) or cloud key-management-service-backed signing key custody.
- Commission an independent third-party penetration test and formal security assessment.
- Extend RBAC to attribute-based access control (ABAC) for finer-grained, context-aware policy decisions.
- Add anomaly detection over the audit log (e.g. impossible-travel or brute-force login pattern detection).
- Support additional federation standards (e.g. SCIM for provisioning, WebAuthn/passkeys for passwordless MFA).
- Improve horizontal scalability and high-availability configuration of the identity provider.
- Extend administrative governance workflows (approval chains for role escalation, periodic access review).

5.3 Professional Learning & Individual Reflection

New Knowledge Acquired

- Learned to design a security-critical system around trust boundaries and verifiable state transitions rather than isolated login screens.
- Developed practical understanding of OAuth2/OIDC and SAML2 federation flows and their respective failure modes.
- Improved knowledge of RBAC theory and its translation into an enforceable, testable policy layer.
- Strengthened understanding of secure token/secret handling, audit-log design, and fail-closed security defaults.
- Learned to distinguish prototype evidence from claims that require enterprise-scale validation and independent security review.

Engineering & Professional Skills Developed

- System architecture and modular decomposition of a security-sensitive platform.
- Standards-based protocol integration and API contract reasoning.
- Debugging and end-to-end verification of authentication and authorization flows.
- Access-control policy design and audit-trail engineering.
- Technical documentation and evidence-based reporting.
- Engineering trade-off analysis, risk assessment and professional communication.

Individual Reflection

The most difficult engineering problem was maintaining a reliable, verifiable chain from a single login event to every downstream access decision. A component could appear correct in isolation — for example, token issuance working correctly — while the overall workflow still failed because of clock skew, audience mismatch, or a relying application accepting an unsigned or expired token. I addressed this by testing the system progressively from credential submission through token issuance, validation, RBAC evaluation and audit-log persistence, rather than validating only the final login screen.

A key engineering decision I contributed to was making every protected boundary fail closed and re-validate tokens and roles independently, instead of trusting a session for its full lifetime once granted. This decision was informed by zero-trust principles and by the risk that a single compromised or misconfigured relying application should not be able to silently expand its own trust.

I independently strengthened my understanding of OAuth2/OIDC, SAML2, RBAC theory, secure secret management and audit-log design. The project also taught me that the engineering quality of an identity system depends as much on what it refuses (fail-closed validation, least-privilege defaults) as on the features it grants.

If the project were repeated, I would establish the token/session observability and automated integration-test suite earlier. A broader set of automated cross-application federation tests and a formal threat model would make it possible to quantify security coverage more rigorously instead of relying mainly on functional prototype validation.

REFERENCES

1. T. Lodderstedt, J. Bradley, A. Labunets, and D. Fett, “RFC 9700: Best Current Practice for OAuth 2.0 Security,” Internet Engineering Task Force (IETF), Jan. 2025. doi: 10.17487/RFC9700.
2. D. Fett, B. Campbell, J. Bradley, T. Lodderstedt, M. Jones, and D. Waite, “RFC 9449: OAuth 2.0 Demonstrating Proof of Possession (DPoP),” Internet Engineering Task Force (IETF), Sep. 2023. doi: 10.17487/RFC9449.
3. T. Lodderstedt, J. Richer, and B. Campbell, “RFC 9396: OAuth 2.0 Rich Authorization Requests,” Internet Engineering Task Force (IETF), May 2023. doi: 10.17487/RFC9396.
4. R. Hedberg, M. B. Jones, A. Å. Solberg, J. Bradley, G. De Marco, and V. Dzhuvinov, “OpenID Federation 1.0,” OpenID Foundation, Feb. 2026.
5. N. Sakimura, J. Bradley, M. Jones, B. de Medeiros, and M. Mortimore, “OpenID Connect Core 1.0 incorporating errata set 2,” OpenID Foundation, Dec. 2023.
6. D. Temoshok, Y.-Y. Choong, R. Galluzzo, M. LaSalle, A. Regenscheid, D. Proud-Madruga, S. Gupta, and N. Lefkovitz, “NIST SP 800-63-4: Digital Identity Guidelines,” National Institute of Standards and Technology, Aug. 2025. doi: 10.6028/NIST.SP.800-63-4.
7. R. Chandramouli and Z. Butcher, “A Zero Trust Architecture Model for Access Control in Cloud-Native Applications in Multi-Location Environments,” NIST Special Publication 800-207A, National Institute of Standards and Technology, Sep. 2023. doi: 10.6028/NIST.SP.800-207A.
8. OWASP Foundation, “OWASP Application Security Verification Standard (ASVS) 5.0.0,” OWASP Foundation, 2025. The stable ASVS 5.0.0 release was published in May 2025.
9. OpenID Foundation, “OpenID Connect for Identity Assurance 1.0,” OpenID Foundation, Oct. 2024.
10. OpenID Foundation, “OpenID Identity Assurance Schema Definition 1.0,” OpenID Foundation, Oct. 2024.

APPENDICES

Appendix A — Architecture and Flow Evidence

Figure A.1 System Architecture of the Federated IAM Platform

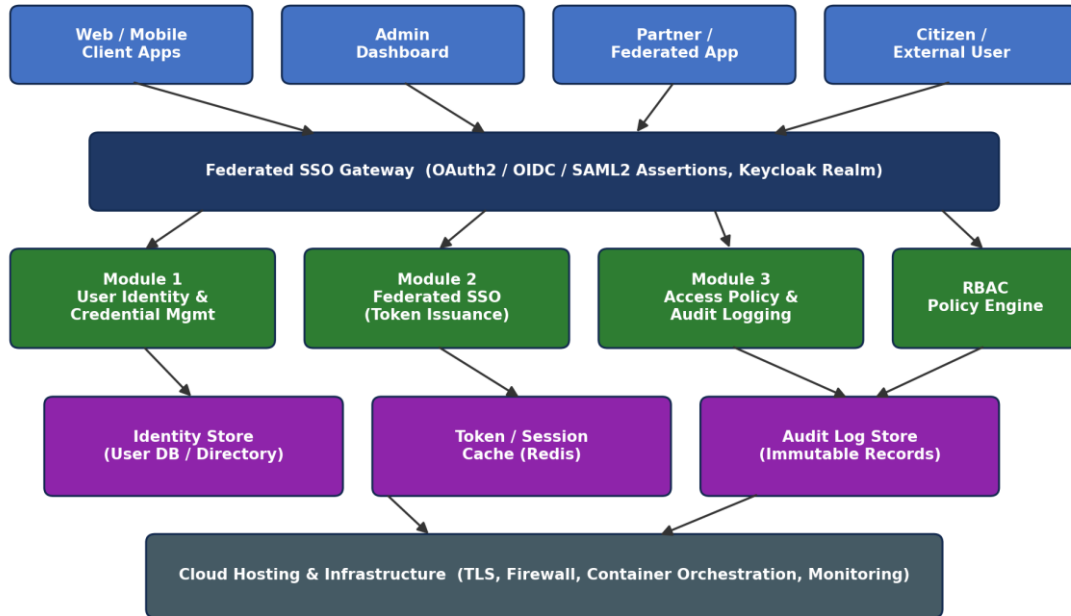


Figure A.1 System architecture of the federated IAM platform.

Figure A.2 Federated SSO Authentication and Authorization Sequence Flow

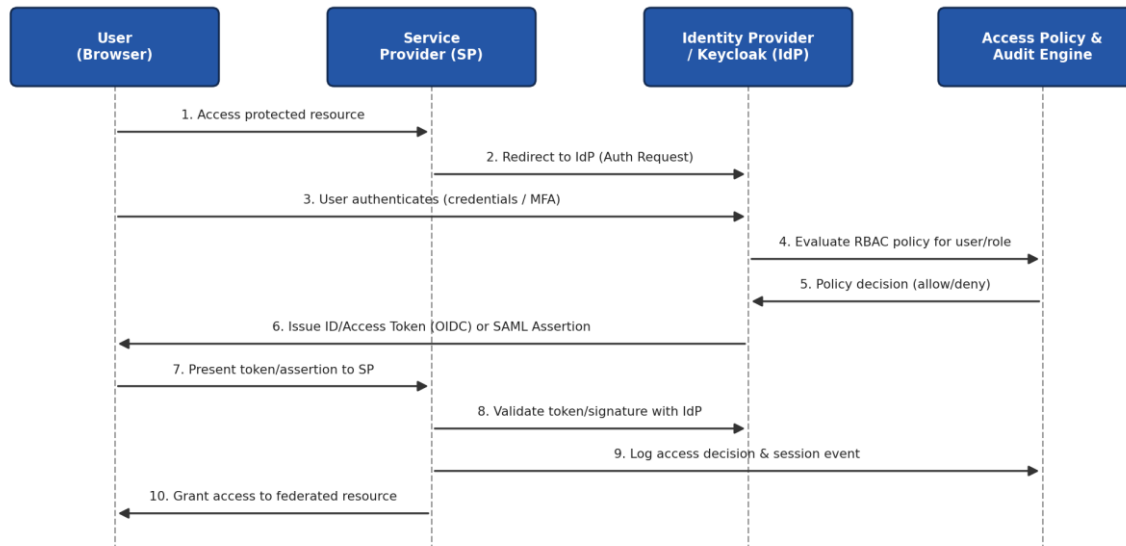


Figure A.2 Federated SSO authentication and authorization sequence flow.

The architecture evidence shows the major identity, federation, policy-enforcement and audit stages, and the sequence in which a single login event is converted into a trusted, role-checked, logged access decision across relying applications.

Appendix B — Core API / Interface Summary

Endpoint / Interface	Purpose
POST /api/v1/auth/register	Register a new user identity.
POST /api/v1/auth/login	Authenticate credentials and initiate the federation flow.
GET /oauth2/authorize	OAuth2/OIDC authorization endpoint (Keycloak).
POST /oauth2/token	Token endpoint — exchange authorization code for tokens.
POST /saml2/sso	SAML2 Web Browser SSO endpoint.
GET /api/v1/users/	Retrieve user identities (admin-scoped).
GET /api/v1/roles/	Retrieve role and permission definitions.
POST /api/v1/roles/assign	Assign or update a user's role.
GET /api/v1/audit-logs/	Retrieve audit log records (admin-scoped).
POST /api/v1/sessions/revoke	Revoke an active session/token.

Appendix C — Access Decision Logic

The operational chain is: submit credentials → authenticate at IdP (with optional MFA) → issue signed token/assertion → relying application validates signature, audience and expiry → policy layer evaluates caller's role against the resource's required permission → allow/deny decision → write audit record → (for allowed requests) serve the protected resource.

The RBAC evaluation considers the authenticated user's assigned role(s), the resource's required permission, and any resource-scoped constraints (for example, tenant or zone scoping). The project working record uses an illustrative role set of Administrator, Application Owner, Standard User and Auditor; these are prototype configuration roles rather than a fixed organisational policy.

Appendix D — Identity & Token Data Model (Summary)

Entity	Key Attributes
User	user_id, email, hashed_credential, mfa_enabled, created_at
Role	role_id, name, description, permission_set
User-Role Assignment	user_id, role_id, assigned_by, assigned_at
Federated Client (Relying Party)	client_id, protocol (OIDC/SAML2), redirect/ACS URL, allowed scopes
Token/Session	token_id, user_id, client_id, issued_at, expires_at, revoked
Audit Record	audit_id, actor, action, resource, decision, correlation_id, timestamp

This structure supports later quantitative evaluation (e.g. access-review reporting) without fabricating values in the capstone report.

Appendix E — Individual Contribution Evidence

Evidence Item	Individual Relevance
System architecture figure	Supports architecture and integration contribution.
Federation sequence-flow figure	Supports design of the identity-to-access chain.
API/interface design	Supports system integration responsibility.
End-to-end test matrix	Supports testing and engineering judgment.
Deployment/build verification records	Supports integration and deployment responsibility.
Individual reflection	Supports independent learning outcome.

Appendix F — Capstone Project Outcome Mapping

Outcome / Area	Evidence in This Report
Complex engineering problem formulation	Chapter 1 problem statement and constraints
Engineering design under constraints	Chapter 3 requirements, alternatives, trade-offs and risk register
Written/oral technical communication	Whole report, tables, figures and viva preparation
Ethics and professional responsibility	Chapter 3.7 and declaration
Teamwork and leadership	Chapter 4.8 roles and integration responsibilities
Experimentation and engineering judgment	Chapter 4.3–4.5 test plan and analysis
Independent acquisition of knowledge	Chapter 5.3 reflection
Standards	Chapter 3.2
Sustainability and societal impact	Chapter 3.7
Risk assessment and mitigation	Chapter 3.7 (risk register)
Security considerations	Chapter 3.7 and Appendix C
Integrated/system-level engineering	Chapter 3.5 and Appendix A
Project planning and management	Chapter 4.8
Individual contribution	Contribution Statement, Chapter 4 and Appendix E